Risk Communication

Executive Board Report · Stakeholder Communication Plan · Risk Dashboard · KPI Framework

Communicates the results of the HVMC risk programme to every audience, from the board to clinical staff

Project Name	Healthcare IAM Operations Simulation
Organization	Horizon Valley Medical Center (HVMC)
Rubric	Risk Communication (Semester 4, Week 11)
Deliverables	**HVMC_Board_Risk_Report.pdf** (10-slide board pack) · **HVMC_Risk_Dashboard.html** (interactive dashboard) · **kri_monitor.py** + **kri_status.json** (automated alerting) · **HVMC_KPI_Tracker.xlsx** (tracking system) · this report
Prepared By	Sabitha S Karanavar
Report Date	October 14, 2026

Rubric Cross-Reference

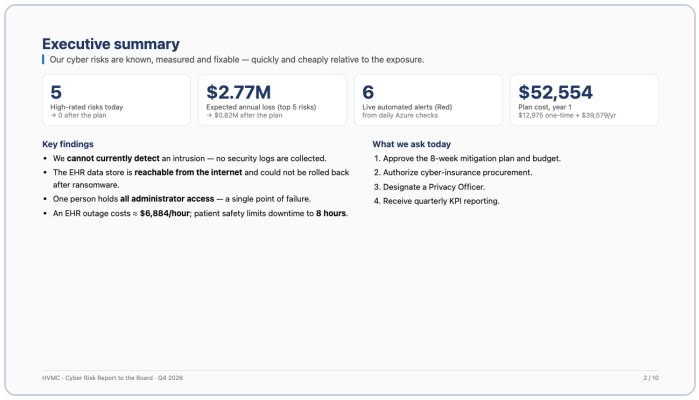
Rubric requirement	Section	Evidence
Structured executive risk report with key findings, financial impact analysis and actionable recommendations, formatted for board presentation	1 + board pack	10-slide landscape board pack: executive summary, top risks in plain language, financial impact chart, exposure, 8 owned and dated recommendations, roadmap, 5 board resolutions
Stakeholder communication plan with audience analysis, tailored messaging and schedules	2 + tracker	10 audiences on an interest/influence grid; needs, technical level, key message, channel, frequency, owner and feedback per audience; dated and recurring schedule; incident communications
Visual risk dashboard with key metrics, automated alerting and drill-down	3 + dashboard	Interactive HTML dashboard; daily automated KRI collection from Azure with Red-status alerts; drill-down from heat map, KRIs, KPIs and assets to risk detail, evidence and history
KPI framework with leading/lagging indicators, tracking systems and documented review processes	4 + tracker	6 leading + 6 lagging KPIs with thresholds and owners; monthly tracking workbook with automatic status; KRI log; review cadences and records

Live status at 2026-10-14T18:34:16Z: automated checks of the HVMC Azure tenant report ✕ **Red** 6 ! **Amber** 9 ✓ **Green** 0 key risk indicators, so six alerts are open. They match the gaps the plan is designed to close.

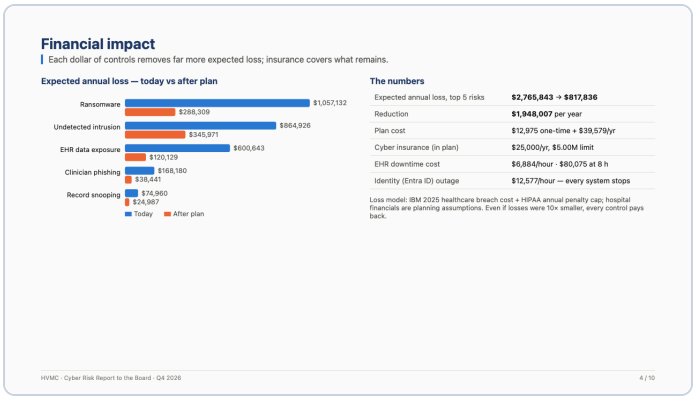
1. Executive Risk Report for the Board

The board pack (**HVMC_Board_Risk_Report.pdf**) is written for non-technical directors. Every slide opens with a one-line takeaway; risks are described by business consequence rather than technology; numbers are rounded to what matters for a decision; and the pack ends with explicit resolutions to vote on.

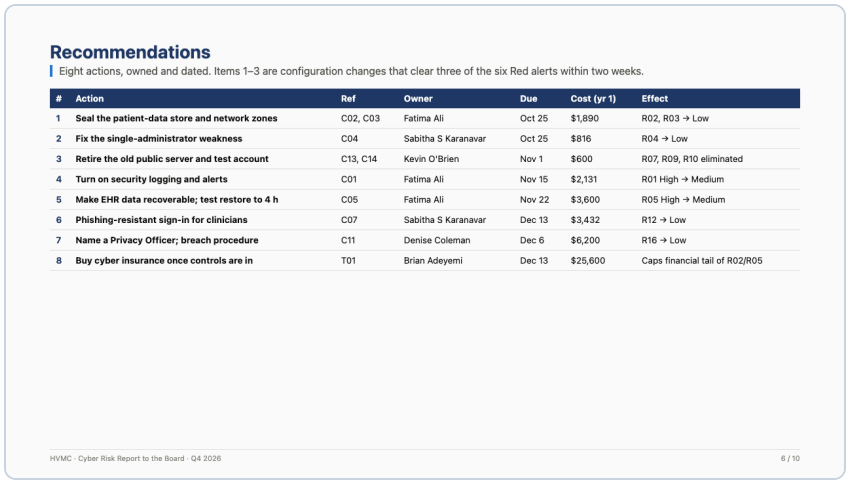
Slide	Title	Purpose and content
1	Title	Meeting, presenter (Security & Risk Lead), confidentiality
2	Executive summary	Four headline numbers (High risks, expected loss, live alerts, plan cost); four key findings; four requests
3	Top five risks in plain language	What could happen, why, business impact, owner, rating today → after plan
4	Financial impact	Expected annual loss today vs after plan (chart); plan cost; insurance; downtime cost per hour
5	Where we are exposed	Top critical assets, exposure, dependants; single points of failure
6	Recommendations	Eight actions, each with owner, due date, year-1 cost and effect on risk
7	Roadmap	Three phases over 8 weeks; resources; residual risk after the plan
8	Decisions requested	Five resolutions with approval boxes
9	What the board will track	Six KPIs with today's value, December target and thresholds
10	Appendix	Method and sources, for directors who want the detail



Slide 2 — Executive summary



Slide 4 — Financial impact



1.1 Board-presentation design choices

- **Bottom line up front:** the answer (risks are fixable for ~$53K) comes before the analysis.
- **Decision-oriented:** each recommendation names an owner, a date and a cost; slide 8 turns them into votes.
- **One message per slide** in a coloured kicker line; landscape 16:9 for projection.
- **Status never by colour alone:** ratings carry an icon and a label, so they read in print and for colour-blind directors.

2. Stakeholder Communication Plan

2.1 Audience analysis

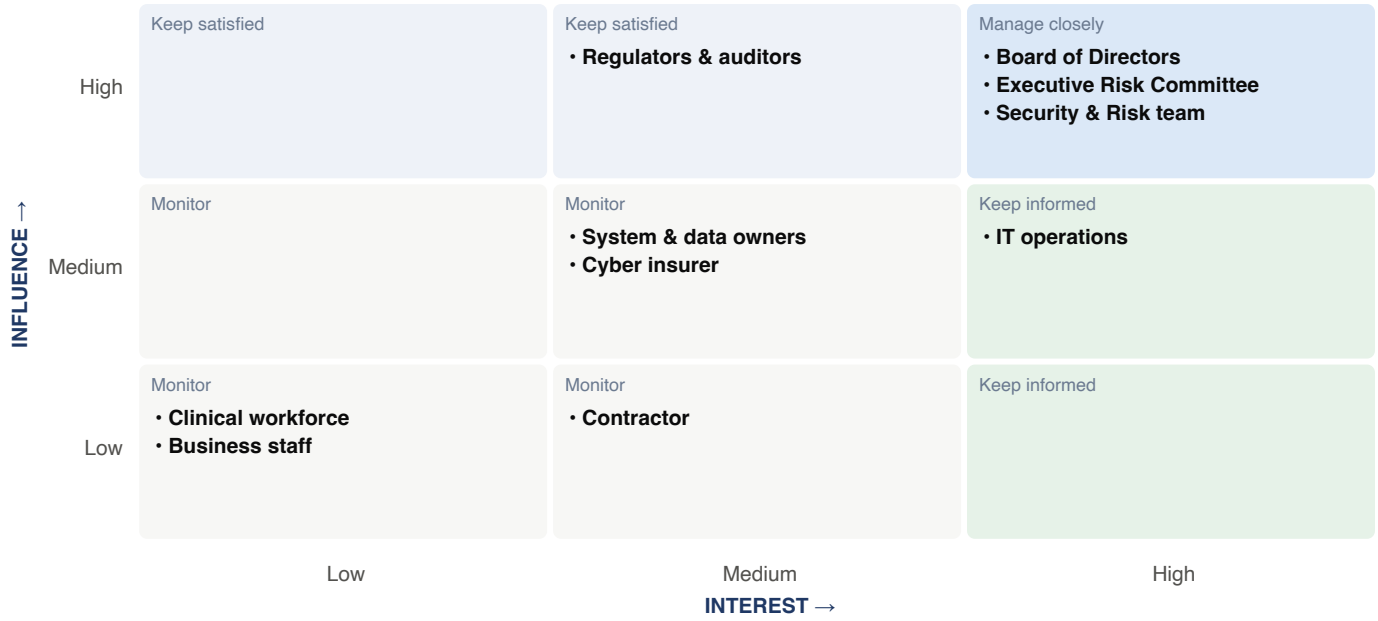


Figure 1 — Stakeholders by interest and influence, which sets how closely each is engaged.

Audience	Interest	Influence	Technical level	Information needs
Board of Directors Board (external to tenant)	High	High	Low	Overall posture, financial exposure, decisions required, regulatory standing
Executive Risk Committee CEO, CFO, CMO + Denise Coleman	High	High	Medium	Trend vs plan, budget, residual risks to accept, escalations
Security & Risk team Denise Coleman, Anthony Ruiz	High	High	High	Live KRIs, alerts, control test results
IT operations Kevin O'Brien, Fatima Ali, Jason Park	High	Medium	High	Assigned tasks, due dates, technical detail, change windows
System & data owners Sarah Chen, Elena Petrova, David Patel, Grace Nguyen, Daniel Osei, Brian Adeyemi	Medium	Medium	Low	Risks to their system, downtime targets, decisions they own
Clinical workforce Doctors (5), nurses (7), lab (3), pharmacy (3)	Low	Low	Low	What changes for them (passkeys, downtime procedures), why, and when
Business staff Reception, HR, Finance	Low	Low	Low	New rules (sanction policy, training), sign-in changes
Contractor Carlos Diaz (IT contractor)	Medium	Low	High	Access terms, BAA obligations, expiry
Regulators & auditors HHS OCR, external auditor	Medium	High	Medium	Evidence of risk analysis, management, and breach handling
Cyber insurer Insurance carrier / broker	Medium	Medium	Medium	Control attestations (MFA, backups, logging)

2.2 Tailored messaging, channels and owners

Audience	Key message	Format / channel	Frequency	Owner	Feedback loop
Board of Directors	“HVMC's biggest cyber risks are known and fixable for under $53K this year; we ask you to approve the plan and insurance.”	Quarterly board pack (slides) + dashboard summary	Quarterly; ad hoc for Critical	Denise Coleman	Board Q&A; minutes
Executive Risk Committee	“Plan is on track / off track; these residual risks need your acceptance.”	Monthly meeting with dashboard walk-through	Monthly	Denise Coleman	Decision log
Security & Risk team	“Every Red KRI is an alert to triage within 1 business day.”	Live dashboard + automated alerts (email/Teams)	Continuous; weekly stand-up	Anthony Ruiz	Alert ticket closure
IT operations	“Phase 1 quick wins (storage, NSG, admin) by Oct 31 clear 3 of the 6 Red KRIs.”	Task board + weekly status in Teams	Weekly	Kevin O'Brien	Task status updates
System & data owners	“Your system's recovery target is X hours; here is what changes for your team.”	Monthly one-page system brief	Monthly; at go-live of changes	Denise Coleman	Owner sign-off on acceptance
Clinical workforce	“A quick passkey sign-in protects your patients' records; here is how to set it up.”	Huddle briefings, intranet notice, 2-minute how-to video	At each rollout; annual training	Sabitha S Karanavar	Help-desk ticket trends
Business staff	“Complete your HIPAA training by Dec 13; report anything suspicious to Jason Park.”	Email + team meetings	At rollout; quarterly reminder	Daniel Osei	Training completion rate
Contractor	“Your access ends on the contract date and is reviewed quarterly under the BAA.”	Formal letter + BAA	At contract start/renewal	Kevin O'Brien	Signed BAA
Regulators & auditors	“HVMC performs and documents risk analysis and acts on it (HIPAA §164.308(a)(1)).”	Formal reports on request; breach notices	On request; within 60 days of breach discovery	Privacy Officer (to be designated)	Audit findings
Cyber insurer	“Controls C01, C05, C07 are in place and tested.”	Application questionnaire; renewal attestation	Annually; at claim	Brian Adeyemi	Premium and terms

2.3 Messaging principles

- **Executives** get consequences, money and decisions; **IT** gets tasks, dates and technical detail; **clinicians** get what changes for them and why it protects patients.
- The same facts drive every message (one risk register, one dashboard), so audiences never hear conflicting numbers.
- Bad news travels fast: any Critical event reaches executives within 1 hour, regardless of the schedule.

2.4 Communication schedule

When	Communication	Audience	Owner
Oct 19, 2026	Plan kick-off brief; Phase 1 tasks assigned	IT operations; Security team	Denise Coleman
Oct 21, 2026	Board pack: risk report and plan approval request	Board; Executive Risk Committee	Denise Coleman
Oct 26, 2026	System briefs: recovery targets and changes	System & data owners	Denise Coleman
Nov 2, 2026	Phase 1 results: KRIs turned Green	Executive Risk Committee	Anthony Ruiz
Nov 16, 2026	Passkey rollout notice + how-to	Clinical workforce; Business staff	Sabitha S Karanavar
Nov 30, 2026	Monthly KPI review	Executive Risk Committee	Denise Coleman
Dec 13, 2026	Plan completion report; residual-risk acceptance	Executive Risk Committee; owners	Denise Coleman
Jan 2027	Quarterly board update (Q4 KPIs)	Board	Denise Coleman
Weekly	IT status stand-up	IT operations	Kevin O'Brien

When	Communication	Audience	Owner
Daily (automated)	kri_monitor.py run; Red KRI → alert	Security team	Anthony Ruiz
Monthly	Dashboard review + checklist re-run	Executive Risk Committee	Anthony Ruiz
Quarterly	Board pack; control tests; residual re-score	Board; owners	Denise Coleman
Annually	Strategy, weights and appetite review; insurer renewal	Board; Executive Risk Committee	Denise Coleman
Event	Critical incident: exec notice within 1 h; breach assessment; §164.404 notice ≤ 60 days	Executives; OCR; patients	Privacy Officer

2.5 Incident communications

Time from detection	Action	Owner
≤ 1 hour	Notify Security & Risk Lead and executives of any Critical incident	Anthony Ruiz
≤ 24 hours	Holding statement to staff; brief board chair; contact insurer's breach line	Denise Coleman / Brian Adeyemi
≤ 5 days	HIPAA breach-risk assessment completed and documented	Privacy Officer
≤ 60 days	Notify affected individuals; HHS (and media if ≥ 500 residents of a state) per §164.404–408	Privacy Officer

3. Visual Risk Dashboard

HVMC_Risk_Dashboard.html is a single self-contained file that opens in any browser, with no server or internet needed. It is built for the Security team and the Executive Risk Committee, and it supports light and dark mode, keyboard navigation and a data-table view.

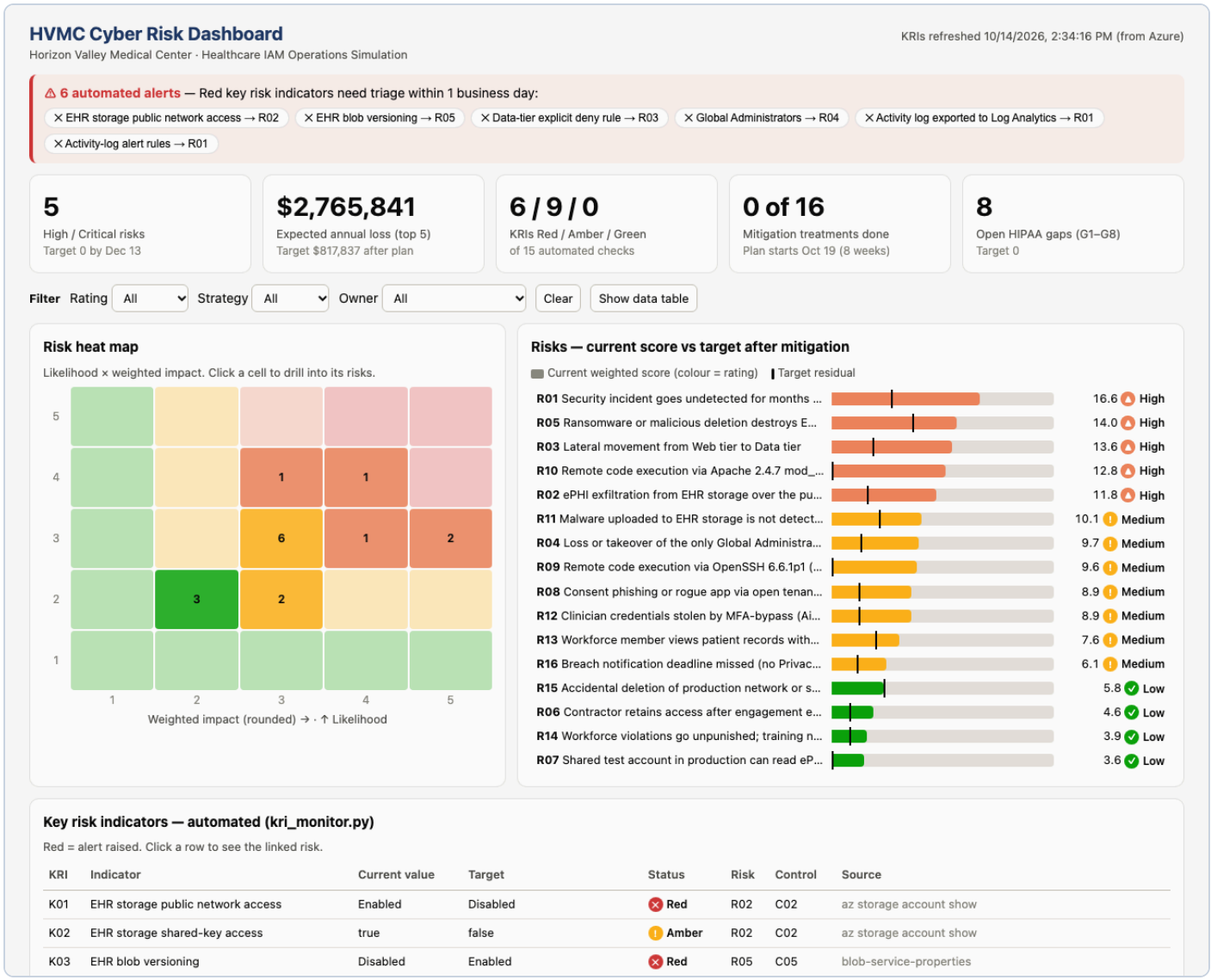


Figure 2 — Dashboard overview: automated alert banner, key metrics, filters, heat map and risk ranking.

3.1 Key metrics

Metric	Value today	Why it is on the dashboard
High / Critical risks	5 (target 0)	The board's primary posture measure
Expected annual loss (top 5)	$2,765,841 (target $817,837)	Financial exposure in board language
KRIs Red / Amber / Green	6 / 9 / 0	Live control health from Azure
Mitigation treatments done	0 of 16	Delivery progress against the plan
Open HIPAA gaps	8 (target 0)	Compliance standing

3.2 Automated alerting

Alerting runs at two layers:

Layer 1 — daily KRI collection (implemented). `kri_monitor.py` runs 15 read-only Azure CLI / Microsoft Graph queries, compares each value with its threshold and writes `kri_status.json`, which the dashboard displays. It exits with code 2 whenever any KRI is Red, so a scheduler (cron, Azure Automation or a CI pipeline) can raise a notification. Its first run, against the live tenant, produced:

KRI	Indicator	Value	Target	Status	Risk / control
K01	EHR storage public network access	Enabled	Disabled	✕ Red	R02 / C02
K02	EHR storage shared-key access	True	false	! Amber	R02 / C02
K03	EHR blob versioning	Disabled	Enabled	✕ Red	R05 / C05
K04	Blob soft-delete retention (days)	7	≥ 30	! Amber	R05 / C05
K05	Data-tier explicit deny rule	Missing	Present	✕ Red	R03 / C03
K06	Global Administrators	1	2–4 incl. break-glass	✕ Red	R04 / C04
K07	Activity log exported to Log Analytics	0	≥ 1	✕ Red	R01 / C01
K08	Activity-log alert rules	0	≥ 3	✕ Red	R01 / C01
K09	Network flow logs	0	≥ 1	! Amber	R01 / C01
K10	Defender for Storage	Free	Standard	! Amber	R11 / C06
K11	Security alert contacts	0	≥ 1	! Amber	R11 / C06
K12	Users can register applications	True	false	! Amber	R08 / C08
K13	Guest invitations allowed from	everyone	adminsAndGuestInviters	! Amber	R08 / C08
K14	Test/shared accounts in production	1	0	! Amber	R07 / C14
K15	Resource locks on production RG	0	≥ 1 (accepted risk)	! Amber	R15 / A01

```
# daily at 07:00 — run the monitor and email the Security team if any KRI is Red (exit code 2)
0 7 * * *  cd /opt/hvmc-risk && python3 kri_monitor.py || mail -s "HVMC KRI alert" security@hvmc.example < kri_status.json
```

Layer 2 — real-time Azure Monitor alerts (configured in C01). Once Log Analytics is deployed, activity-log alert rules notify an action group within minutes of risky changes. These are documented here for implementation in Phase 2; they have **not** yet been created in the tenant:

```
az monitor action-group create -g HVMC-CloudSecurity-RG -n hvmc-security --short-name hvmcsec --action email secteam security@hvmc.example
az monitor activity-log alert create -g HVMC-CloudSecurity-RG -n nsg-rule-changed --scope /subscriptions/<sub-id> \
   --condition category=Administrative and operationName=Microsoft.Network/networkSecurityGroups/securityRules/write --action-group hvmc-security
az monitor activity-log alert create -g HVMC-CloudSecurity-RG -n storage-config-changed --scope /subscriptions/<sub-id> \
   --condition category=Administrative and operationName=Microsoft.Storage/storageAccounts/write --action-group hvmc-security
az monitor activity-log alert create -g HVMC-CloudSecurity-RG -n role-assignment-changed --scope /subscriptions/<sub-id> \
   --condition category=Administrative and operationName=Microsoft.Authorization/roleAssignments/write --action-group hvmc-security
```

A break-glass sign-in alert (C04) is a Log Analytics scheduled query on Entra sign-in logs (for example `SigninLogs | where UserPrincipalName startswith "breakglass"`). It requires the sign-in log export enabled by Entra ID P1 (C07).

3.3 Drill-down

Start from	Drill path
Alert banner chip	Red KRI → status, value, target, action → linked risk → its controls, assets and history
Heat-map cell	Filters the ranking to that likelihood × impact cell → risk detail
Risk bar / table row	Risk detail: rating, target after plan, threat, vulnerability, impact factors, treatments with KPIs, live KRIs, assets, change history
KPI card	Definition, direction, thresholds, owner, source, linked risks, monthly actual vs target
Asset row	Asset tier, CIA, dependencies, threats → each linked risk

A breadcrumb (Overview › asset › risk) lets users step back up. Deep links (for example `HVMC_Risk_Dashboard.html#risk=R05`) open a view directly, so a board email can link to the exact risk under discussion.

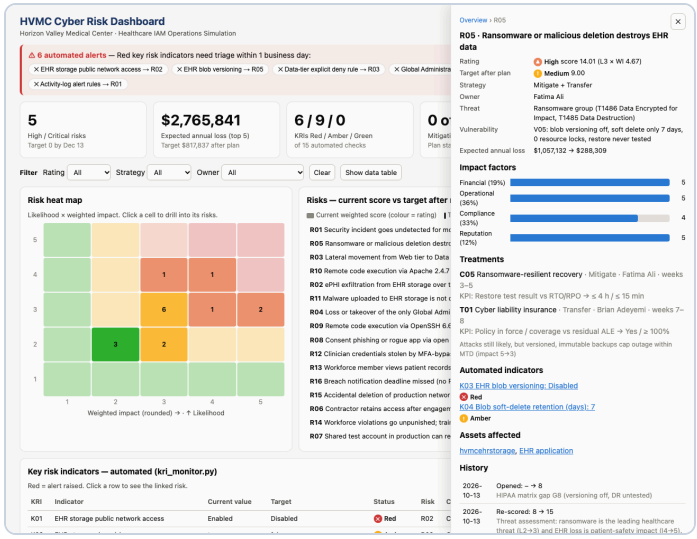


Figure 3 — Drill-down to risk R05 (ransomware)

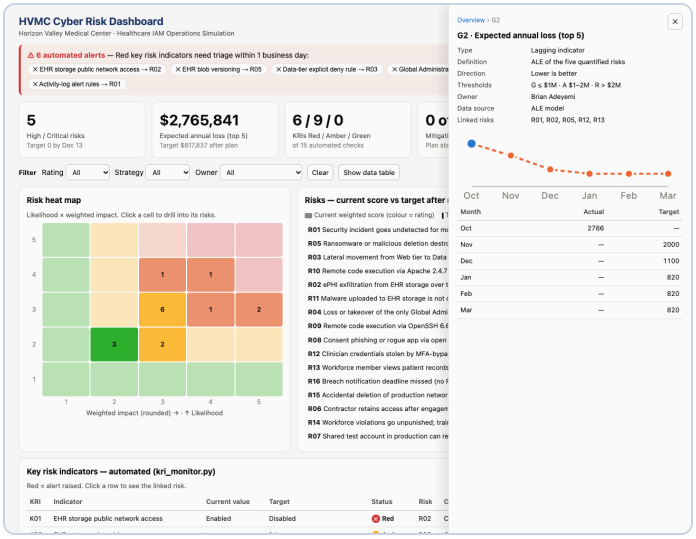


Figure 4 — Drill-down to KPI G2 (expected annual loss)

4. KPI Framework and Tracking

Leading indicators measure whether the work that reduces risk is being done, so they move first. **Lagging indicators** measure whether risk and losses actually fell, so they confirm results after the fact. Each KPI has a definition, direction, Green/Amber/Red thresholds, owner and data source. Four KPIs are marked "not yet measurable" because the controls that produce their data, such as logging and training records, are part of the plan. That is reported honestly rather than estimated.

ID	Type	KPI	Oct (actual)	Nov target	Feb target	Thresholds	Owner	Source
L1	Leading	**Mitigation controls implemented** Treatments from the mitigation plan verified complete	0%	88%	100%	G ≥ plan · A within 10 pts · R > 10 pts behind	Denise Coleman	Mitigation workbook
L2	Leading	**KRIs at Green** Share of the 15 automated KRIs reporting Green	0%	80%	100%	G ≥ 90% · A 60–89% · R < 60%	Anthony Ruiz	kri_monitor.py (daily)
L3	Leading	**Azure checklist pass rate** 27-item CIS-aligned configuration checklist	48%	89%	96%	G ≥ 90% · A 70–89% · R < 70%	Anthony Ruiz	Monthly checklist re-run
L4	Leading	**Phishing-resistant MFA coverage** Clinical + admin users with passkey registered	Not yet measurable	60%	95%	G ≥ 90% · A 60–89% · R < 60%	Sabitha S Karanavar	Entra auth-methods report
L5	Leading	**Access reviews on time** Quarterly group and contractor reviews completed by due date	0%	100%	100%	G 100% · A ≥ 80% · R < 80%	Sabitha S Karanavar	Review log
L6	Leading	**HIPAA training completion** Workforce completing annual training (rolling 12 months)	Not yet measurable	70%	95%	G ≥ 95% · A 80–94% · R < 80%	Daniel Osei	HR training records
G1	Lagging	**High or Critical risks** Risks rated High/Critical on the weighted model	5	1	0	G 0 · A 1–2 · R ≥ 3	Denise Coleman	Risk register
G2	Lagging	**Expected annual loss (top 5)** ALE of the five quantified risks	$2.77M	$1.10M	$0.82M	G ≤ $1M · A $1–2M · R > $2M	Brian Adeyemi	ALE model
G3	Lagging	**Open HIPAA gaps** Gaps G1–G8 from the HIPAA compliance matrix	8	1	0	G 0 · A 1–3 · R ≥ 4	Denise Coleman	HIPAA matrix
G4	Lagging	**Mean time to detect (hours)** Security events detected from occurrence to alert	Not yet measurable	24 h	4 h	G ≤ 4 h · A ≤ 24 h · R > 24 h	Anthony Ruiz	Log Analytics incidents
G5	Lagging	**EHR restore time in drill (hours)** Measured recovery time in quarterly restore test vs RTO 4 h	Not yet measurable	6 h	4 h	G ≤ 4 h · A ≤ 8 h · R > 8 h	Fatima Ali	Restore drill record
G6	Lagging	**ePHI security incidents** Confirmed incidents involving ePHI	Not yet measurable	0	0	G 0 · A 1 (contained) · R ≥ 1 reportable	Denise Coleman	Incident register

4.1 Tracking systems

System	What it tracks	Updated
HVMC_KPI_Tracker.xlsx — Monthly Tracking	Actual vs target for all 12 KPIs, Oct–Mar; status (G/A/R) calculated automatically	Monthly by KPI owners
HVMC_KPI_Tracker.xlsx — KRI Log	Every automated KRI run, with triage ticket and closure date	Daily (automated) + triage
kri_monitor.py / kri_status.json	15 live configuration indicators from Azure	Daily
HVMC_Risk_Dashboard.html	Visual summary of all of the above with drill-down	Rebuilt after each run
HVMC_Risk_Register.xlsx — History	Append-only log of risk re-scores and status changes	On every change

4.2 Documented review process

Cadence	Forum (chair)	Inputs	Outputs / decisions	Record
Daily	Automated run (Anthony Ruiz)	kri_monitor.py	Red → ticket and owner notified within 1 business day	KRI Log
Weekly	IT stand-up (Kevin O'Brien)	Open tickets, plan tasks	Re-plans, blockers escalated	Task board
Monthly	KPI review — Executive Risk Committee (Denise Coleman)	Tracker, dashboard, checklist re-run	Actions on Amber/Red KPIs; budget changes; risk acceptances	Decision log
Quarterly	Board update (Board chair)	Board pack, six board KPIs, control test results	Direction, appetite, approvals	Board minutes
Quarterly	Control tests (control owners)	Restore drill, break-glass test, port test, access reviews	Residual risk re-scored	Risk register
Annually	Framework review (Executive Risk Committee)	Year of trends, incidents, regulation	Revised KPIs, thresholds, weights and appetite	Version history

4.3 Status rules

- Higher-is-better KPIs: **Green** at or above target; **Amber** within 10 points; **Red** otherwise.
- Lower-is-better KPIs: **Green** at or below target; **Amber** up to 25% above target; **Red** otherwise.
- Amber twice in a row, or any Red, is escalated under the HVMC escalation matrix (Risk Management Fundamentals §2.4).

5. Conclusion

HVMC's risk results now reach each audience in the form it needs. The board gets a 10-slide pack with plain-language findings, financial impact and five decisions. Stakeholders get a plan matched to their interest and influence. The Security team and executives get a live, drillable dashboard backed by automated daily checks of the real Azure tenant. A twelve-indicator KPI framework, with tracking and a documented review cycle, keeps progress measurable. The first automated run shows six Red alerts, exactly the gaps the mitigation plan closes in its first five weeks, so the dashboard will show the plan working as each control lands.

References

- ISO 31000:2018 §6.2 Communication and consultation; NIST SP 800-39 (risk communication and monitoring).
- NIST CSF 2.0 (GV.RM, GV.RR — risk strategy and communication); NIST IR 8286 (cyber risk reporting to enterprise risk management).
- COSO, *Developing Key Risk Indicators to Strengthen Enterprise Risk Management*.
- 45 CFR §164.404–408 (breach notification timelines).
- Microsoft Learn: Azure Monitor activity log alerts; action groups; Microsoft Graph authorizationPolicy.
- HVMC risk programme: Fundamentals, Assessment Techniques, Evaluation Methods, Mitigation Planning reports and workbooks.